

Stimuli

56 tasks in 7 CWE classes; each task has a functional test, an attack test and a secure / insecure reference solution



Detector validation

Semgrep rules and attack tests must separate the two reference solutions of a task before their verdicts are used



Knowledge battery (scored automatically)

multiple choice · recognition of insecure vs secure code (class not named)
· explanation · repair (reported separately)



Generation

9 models × 56 tasks × 6 conditions × 5 samples
baseline · reminder · irrelevant notes · dense RAG · hybrid RAG · oracle RAG



Automatic judgement of every program

functional test · attack test (dynamic) · Semgrep (static)
vulnerable = attack verdict where available, otherwise Semgrep verdict



Blind audit

stratified sample of 140 programs and all 63 explanations rated by a scorer model; ratings then checked informally by the authors



Analysis

H1 residual gap · H2 coupling (fixed effects, mixed model)
H3-H5 paired condition contrasts, model as the unit